

601.445/645

Practical Cryptographic Systems

Asymmetric Cryptography I

Instructor: Matthew Green

Housekeeping

- A2 released... tomorrow
 - Will get a spec first, then some additional pieces
- I am trying to keep the schedule up to date...
 - I'm about a lecture behind (it always happens)
 - I've also shifted the quiz dates back — this may result in fewer quizzes (you can still drop 2)

News?

News?

Paper 2026/2158

Formally Modeling the Terrapin Attack on SSH

Jörg Schwenk , Ruhr University Bochum

Fabian Bäumer , Ruhr University Bochum

Marcus Brinkmann , Ruhr University Bochum

Abstract

The Terrapin attack against SSH channel integrity (USENIX Security 2024) used a novel attack vector: attacks on the channel state. Surprisingly, not all AEAD modes of SSH were equally affected by this attack, and it remained an open question if "unaffected" meant "secure". Existing formal models for secure channels are based on stateful encryption. However, these models do not define what the channel state is and how it is used as input to the different AEAD modes.

In this paper, we propose a formal model for channel integrity under partially chosen state. Applied to the Terrapin attack, the chosen state is the SSH sequence number. It uses an abstract stateful encryption interface, for which we provide pseudocode descriptions for the eight most prominent AEAD modes used in SSH. By varying the SND oracle, we can model ciphertext-only (CO; the Terrapin attack), known-plaintext (KPA), and chosen-plaintext (CPA) attacks. This allows us to establish concrete bounds on the security of the AEAD modes. We find that all three Encrypt-then-MAC (EtM) modes and ChaCha20-Poly1305 in SSH are insecure in the CO model. AES-GCM is the only cipher secure in all three model variants. Going beyond Terrapin, we show that Encrypt-and-MAC (EaM) with a CBC cipher is secure, even in the KPA model. In particular, we describe a novel BEAST-like chosen-plaintext attack on the channel integrity of EaM-CBC, which separates the KPA and CPA models for this scheme.

News?

Paper 2026/2158

Formally Modeling the Terrapin Attack on SSH

Jörg Schwenk , Ruhr University Bochum

Fabian Bäumer , Ruhr University Bochum

Marcus Brinkmann , Ruhr University Bochum

Abstract

The Terrapin attack against SSH channel integrity (USENIX Security 2024) used a novel attack vector: attacks on the channel state. Surprisingly, not all AEAD modes of SSH were equally affected by this attack, and it remained an open question if "unaffected" meant "secure". Existing formal models for secure channels are based on stateful encryption. However, these models do not define what the channel state is and how it is used as input to the different AEAD modes.

In this paper, we propose a formal model for channel integrity under partially chosen state. Applied to the Terrapin attack, the chosen state is the SSH sequence number. It uses an abstract stateful encryption interface, for which we provide pseudocode descriptions for the eight most prominent AEAD modes used in SSH. By varying the SND oracle, we can model ciphertext-only (CO; the Terrapin attack), known-plaintext (KPA), and chosen-plaintext (CPA) attacks. This allows us to establish concrete bounds on the security of the AEAD modes. We find that all three Encrypt-then-MAC (EtM) modes and ChaCha20-Poly1305 in SSH are insecure in the CO model. AES-GCM is the only cipher secure in all three model variants. Going beyond Terrapin, we show that Encrypt-and-MAC (EaM) with a CBC cipher is secure, even in the KPA model. In particular, we describe a novel BEAST-like chosen-plaintext attack on the channel integrity of EaM-CBC, which separates the KPA and CPA models for this scheme.

News?

Stealing *Reasoning Traces* from Proprietary LLM APIs

Alexander Panfilov^{1 2 3 4*} David Schmotz^{2 3 4*} Ilia Shumailov^{5*} Luca Beurer-Kellner⁶
Joachim Schaeffer¹ Ameya Prabhu^{2 4 7‡} Jonas Geiping^{2 3 4‡} Maksym Andriushchenko^{2 3 4‡}

¹ MATS Research

² ELLIS Institute Tübingen

³ Max Planck Institute for Intelligent Systems

⁴ Tübingen AI Center

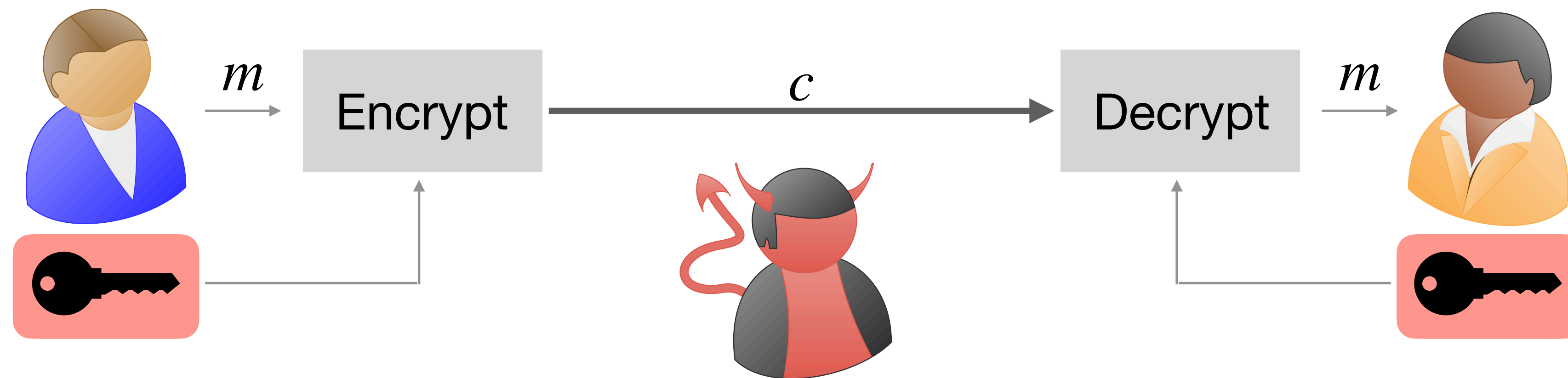
⁵ AI Seurity Company

⁶ Snyk

⁷ University of Tübingen

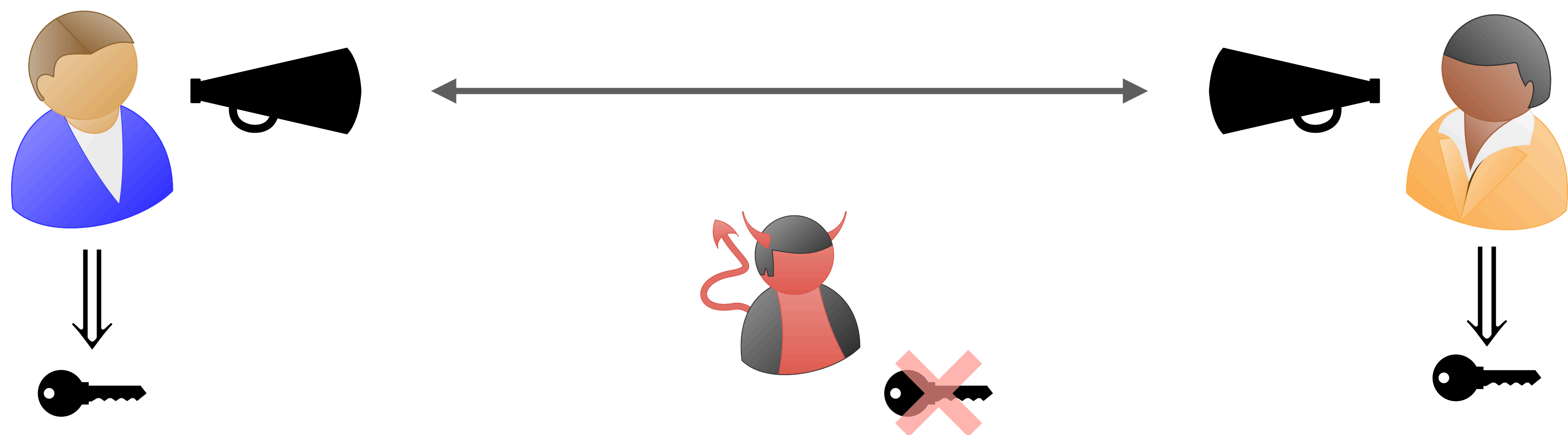
**Equal contribution, order decided by dice roll · ‡Equal supervision*

Review



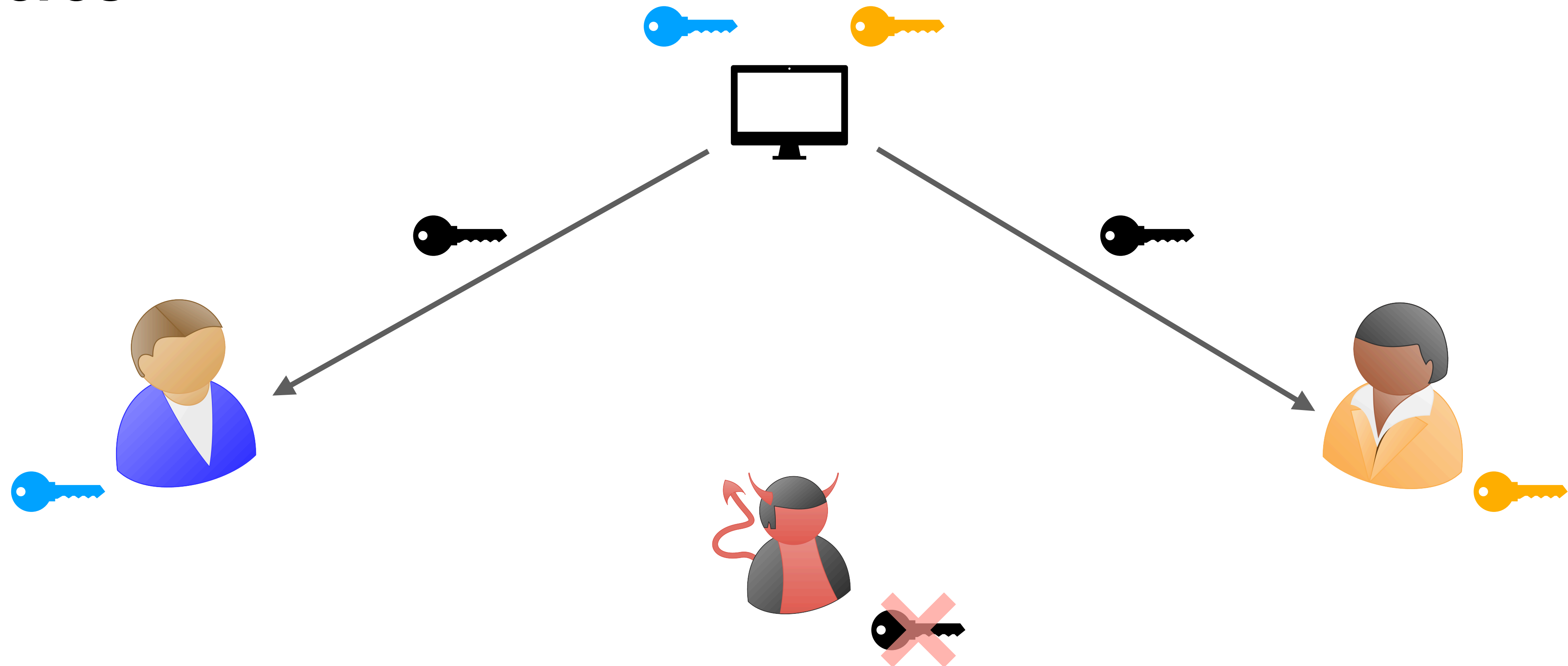
How do parties agree on a common key?

Key Exchange



Key Exchange

Kerberos



Drawbacks?

Asymmetric Cryptography

- Aka “public-key” crypto
 - Gives us a way to encrypt material without pre-existing shared secrets



Diffie-Hellman Key Exchange

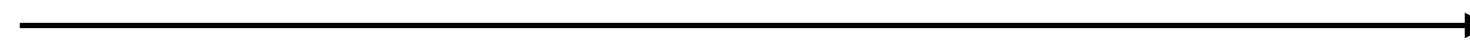
Agreeing on a common secret over an untrusted/public channel

Key Idea: Exploiting asymmetry

Often present in the real world!



No key required



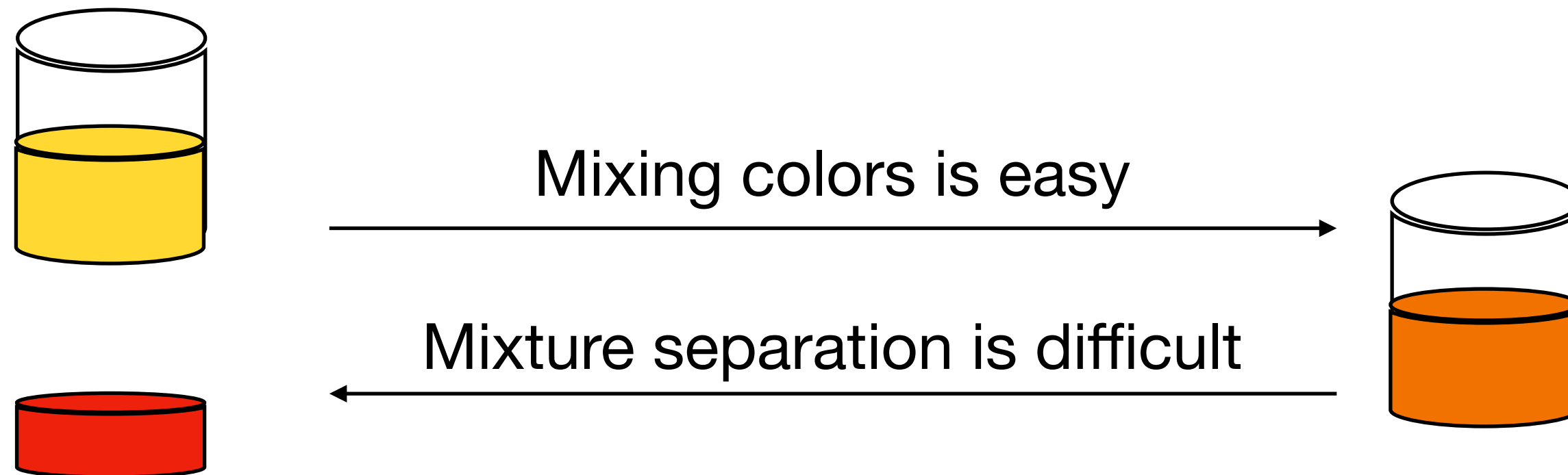
Difficult without a key



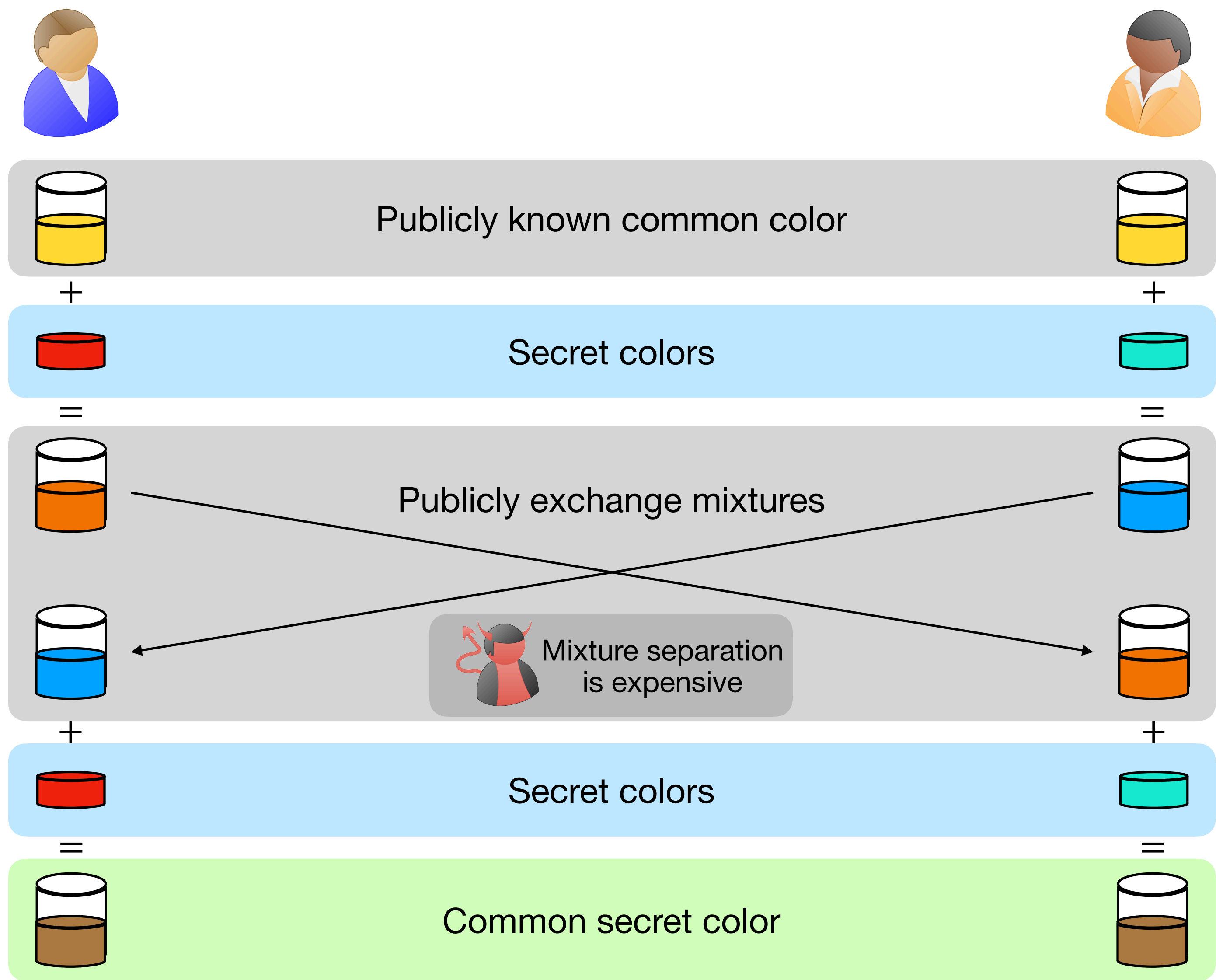
Diffie-Hellman Key Exchange

Agreeing on a common secret over an untrusted/public channel

Key Idea: Exploiting asymmetry



Diffie-Hellman Key Exchange



Mathematical
equivalent of the
mixture separation?

Modular Arithmetic

- $\mathbb{Z}$: The set of integers
- Let $a, N \in \mathbb{Z}$ with $N > 1$

$[a \bmod N] \equiv$ remainder when a is divided by N

where remainder is in $\{0, \dots, N - 1\}$

- For any $a, b, N \in \mathbb{Z}$ with $N > 1$

If $[a \bmod N] = [b \bmod N]$ then we say “ a is congruent to b modulo N ” and denote it by

$$a \equiv b \bmod N$$

Modular Arithmetic

- Let $a \equiv c \pmod{N}$ and $b \equiv d \pmod{N}$

- $a + b \equiv c + d \pmod{N}$

- $a - b \equiv c - d \pmod{N}$

- $a \cdot b \equiv c \cdot d \pmod{N}$

$\implies$ Reduce by the modulus and then perform the arithmetic operation

- What about division?

Modular Arithmetic

Division

- Division in modular arithmetic
 - If $a \equiv c \pmod{N}$ and $b \equiv d \pmod{N}$ then

$[a/b \pmod{N}]$ need not equal $[c/d \pmod{N}]$

- It may not even be well defined:

$$12 \equiv 4 \pmod{4} \text{ and } 5 \equiv 1 \pmod{4}$$

$$\text{But } 12/5 \not\equiv 4/1 \pmod{4}$$

$\implies ab \equiv cb \pmod{N}$ **does NOT imply** $a \equiv c \pmod{N}$

Example: $a = 5, c = 9, b = 2, N = 8$.

Modular Arithmetic

Multiplicative Inverse

- **Multiplicative Inverse:** Given $b \in \mathbb{Z}$, if there exists $d \in \mathbb{Z}$ such that

$$bd \equiv 1 \pmod{N}$$

then d is called the multiplicative inverse of b modulo N .

- If $b \in \mathbb{Z}$ has a multiplicative inverse modulo N then it has a **unique** inverse in the range $\{0, \dots, N - 1\}$.
- We denote this multiplicative inverse by b^{-1}

Modular Arithmetic

Multiplicative Inverse

- If $ab \equiv cb \pmod{N}$ and b has a multiplicative inverse b^{-1} , then

$$ab \cdot b^{-1} \equiv cb \cdot b^{-1} \pmod{N} \implies a \equiv c \pmod{N}.$$

- Which integers b are invertible modulo N ?

Modular Arithmetic

Multiplicative Inverse

Mod 7	1	2	3	4	5	6
1	1	2	3	4	5	6
2	2	4	6	1	3	5
3	3	6	2	5	1	4
4	4	1	5	2	6	3
5	5	3	1	6	4	2
6	6	5	4	3	2	1

Mod 9	1	2	3	4	5	6	7	8
1	1	2	3	4	5	6	7	8
2	2	4	6	8	1	3	5	7
3	3	6	0	3	6	0	3	6
4	4	8	3	7	2	6	1	5
5	5	1	6	2	7	3	8	4
6	6	3	0	6	3	0	6	3
7	7	5	3	1	8	6	4	2
8	8	7	6	5	4	3	2	1

Modular Arithmetic

Multiplicative Inverse

Mod 7	1	2	3	4	5	6
1	1	2	3	4	5	6
2	2	4	6	1	3	5
3	3	6	2	5	1	4
4	4	1	5	2	6	3
5	5	3	1	6	4	2
6	6	5	4	3	2	1

Mod 9	1	2	3	4	5	6	7	8
1	1	2	3	4	5	6	7	8
2	2	4	6	8	1	3	5	7
3	3	6	0	3	6	0	3	6
4	4	8	3	7	2	6	1	5
5	5	1	6	2	7	3	8	4
6	6	3	0	6	3	0	6	3
7	7	5	3	1	8	6	4	2
8	8	7	6	5	4	3	2	1

Modular Arithmetic

Multiplicative Inverse

- If $ab \equiv cb \pmod{N}$ and b has a multiplicative inverse b^{-1} , then

$$ab \cdot b^{-1} \equiv cb \cdot b^{-1} \pmod{N} \implies a \equiv c \pmod{N}.$$

- Which integers b are invertible modulo N ?

b has a multiplicative inverse modulo N if and only if

b is co-prime to N i.e., $\gcd(b, N) = 1$.

If N is a prime number then each element in $\{1, \dots, N-1\}$ has a multiplicative inverse.

Group

- An (abelian) group is a set $\mathbb{G}$ with an operation $\cdot : \mathbb{G} \times \mathbb{G} \rightarrow \mathbb{G}$ such that
 - **Associativity:** $(a \cdot b) \cdot c = a \cdot (b \cdot c)$, for all $a, b, c \in \mathbb{G}$.
 - **Commutativity:** $a \cdot b = b \cdot a$, for all $a, b, c \in \mathbb{G}$.
 - **Identity element:** There exists $e \in \mathbb{G}$ such that for all $a \in \mathbb{G}$, $e \cdot a = a$.
 - **Inverse element:** For all $a \in \mathbb{G}$, there exists $b \in \mathbb{G}$ such that $a \cdot b = e$.
- Examples: $(\{0\}, +)$, $(\{1\}, \cdot)$, $(\mathbb{Z}_N, +)$, $(\mathbb{Z}_N^*, \cdot)$
- In particular, $\mathbb{Z}_p^* = \{1, \dots, p-1\}$

Cyclic Group

- An (abelian) group is a set $\mathbb{G}$ with an operation $\cdot : \mathbb{G} \times \mathbb{G} \rightarrow \mathbb{G}$ such that
 - **Associativity:** $(a \cdot b) \cdot c = a \cdot (b \cdot c)$, for all $a, b, c \in \mathbb{G}$.
 - **Commutativity:** $a \cdot b = b \cdot a$, for all $a, b \in \mathbb{G}$.
 - **Identity element:** There exists $e \in \mathbb{G}$ such that for all $a \in \mathbb{G}$, $e \cdot a = a$.
 - **Inverse element:** For all $a \in \mathbb{G}$, there exists $b \in \mathbb{G}$ such that $a \cdot b = e$.
 - **Generator:** There exists at least one generator $g \in \mathbb{G}$ such that
$$g^0, g^1, g^2, g^3, \dots$$
 produces every element in the group.

Discrete Logarithm problem

- Discrete logarithm problem

Given: $x \in_R 0, \dots, p - 2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p - 1$$

$$h = g^x$$

Find: x

This problem is hard if for all p.p.t. adversaries, all attackers find x with “small” probability

Discrete Logarithm problem

This means that “reversing” exponentiation is assumed to have super-polynomial running time.

How about the exponentiation itself?

- Discrete logarithm problem

Given: $x \in_R 0, \dots, p - 2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p - 1$$

$$h = g^x$$

Find: x

This problem is hard if for all p.p.t. adversaries, all attackers find x with “small” probability

Discrete Logarithm problem

- Discrete logarithm problem

Given: $x \in_R 0, \dots, p-2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p$$

$$h = g^x$$

Find: x

This problem is hard if for all p.p.t. adversaries, all attackers find x with “small” probability

This means that “reversing” exponentiation is assumed to have super-polynomial running time.

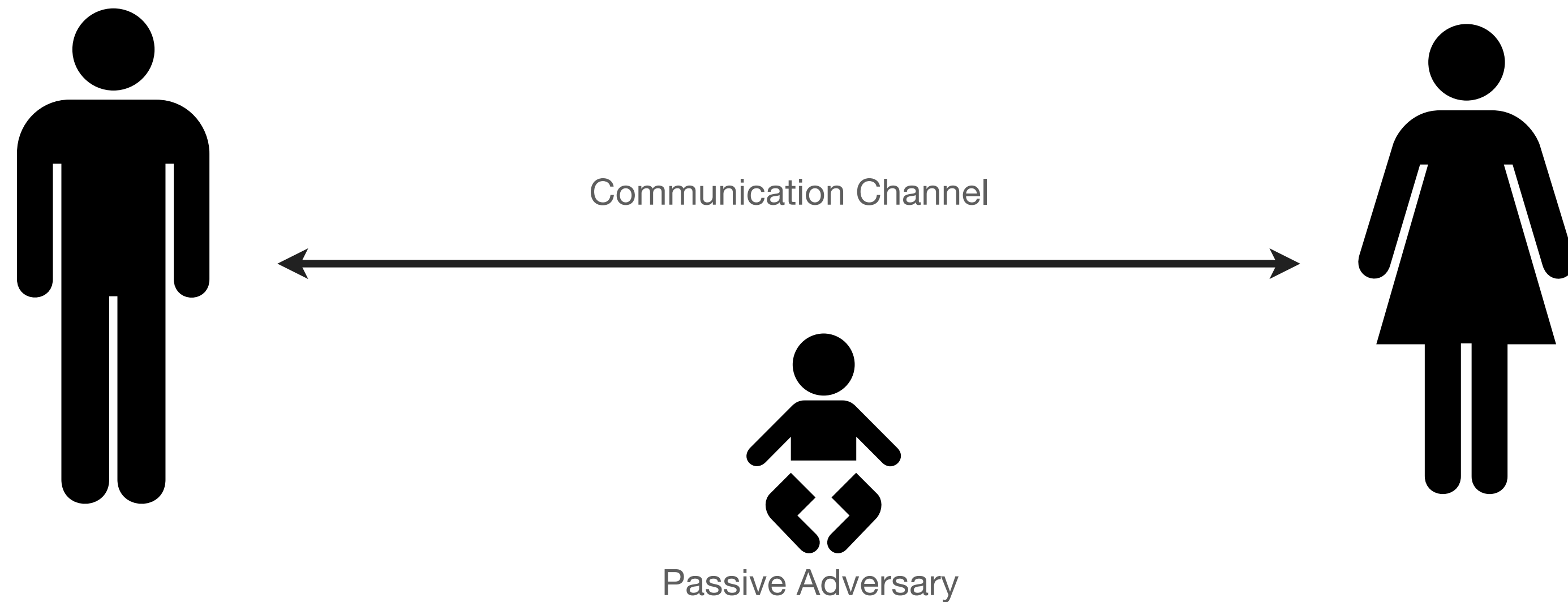
How about the exponentiation itself?

Note that for this to hold, the size of p must be pretty large!

In practice, we typically assume p is at least 1024 bits. And 3072 bits is the minimum in modern protocols!

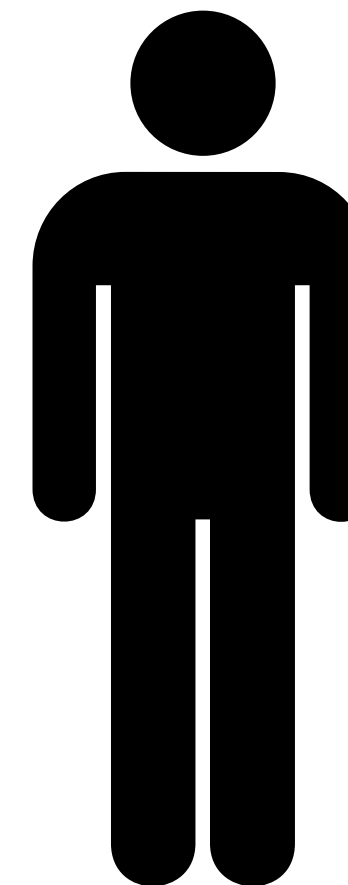
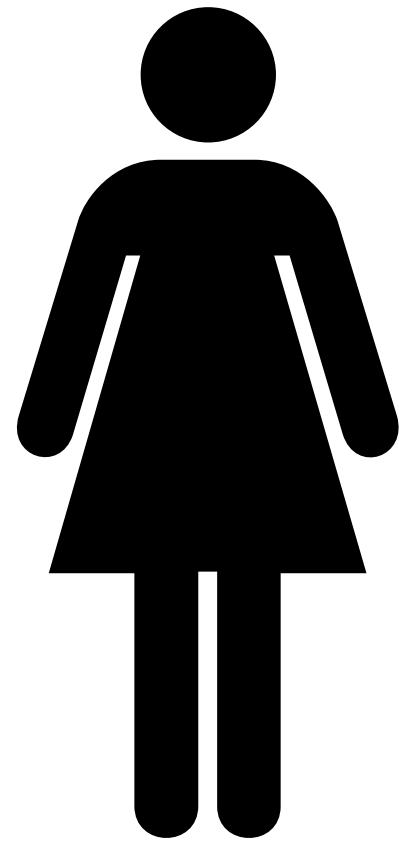
Key Agreement

- Establish a shared key in the presence of a passive adversary



D-H Protocol

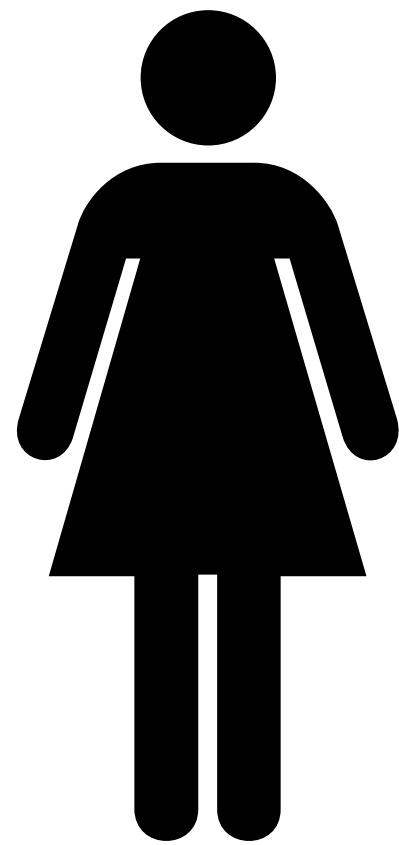
$$p, \langle g \rangle = \mathbb{Z}_p^*$$
$$a \in \mathbb{Z}_{\phi(p)}$$



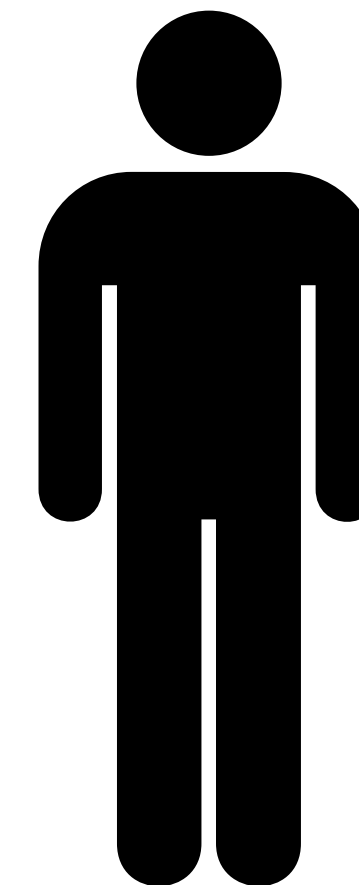
D-H Protocol



$$p, \langle g \rangle = \mathbb{Z}_p^*$$
$$a \in \mathbb{Z}_{\phi(p)}$$



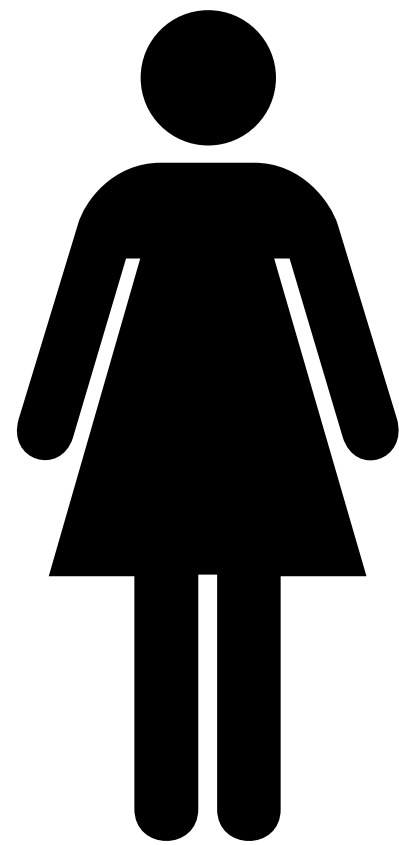
$$p, g, g^a$$



D-H Protocol



$$p, \langle g \rangle = \mathbb{Z}_p^*$$
$$a \in \mathbb{Z}_{\phi(p)}$$



$$b \in \mathbb{Z}_{\phi(p)}$$



p, g, g^a

g^b

D-H Protocol



$$p, \langle g \rangle = \mathbb{Z}_p^*$$
$$a \in \mathbb{Z}_{\phi(p)}$$



$$g^{ba}$$

$$p, g, g^a$$

$$g^b$$

$$b \in \mathbb{Z}_{\phi(p)}$$

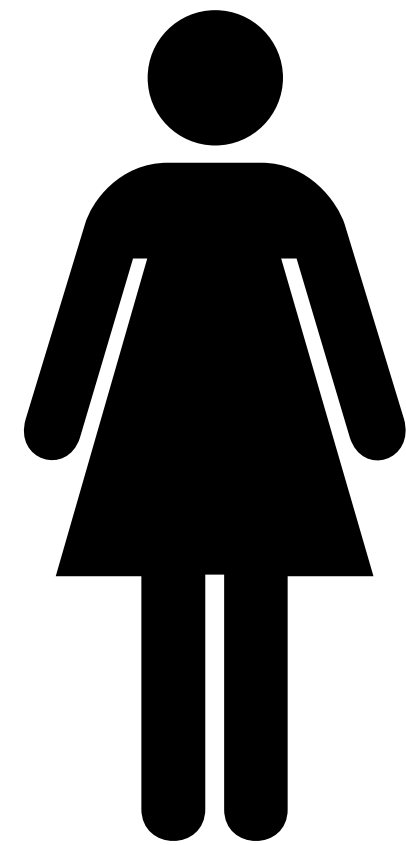


$$g^{ab}$$

D-H Protocol



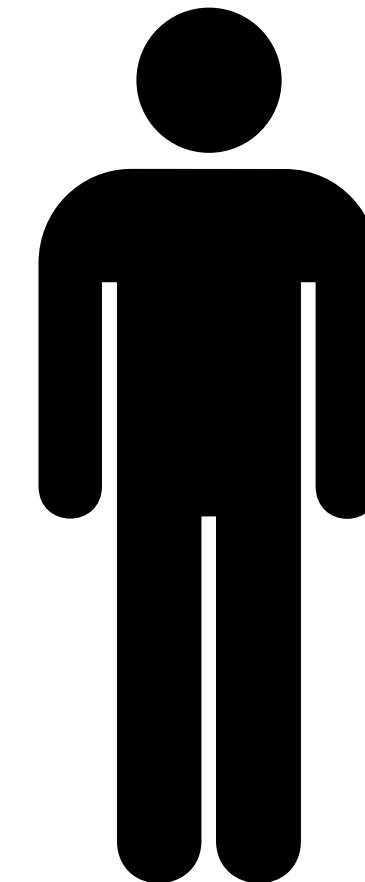
$$p, \langle g \rangle = \mathbb{Z}_p^*$$
$$a \in \mathbb{Z}_{\phi(p)}$$



$$g^{ba}$$



$$b \in \mathbb{Z}_{\phi(p)}$$



$$g^{ab}$$

Usually we “hash” the shared secret value to make a secret encryption key,
and then encrypt using a fast symmetric encryption scheme!

Hard problems (2)

- Diffie-Hellman problem

Given: $a, b \in_R 0, \dots, p-2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p-1$$

$$(g, g^a, g^b)$$

Find: g^{ab}

This problem is hard if for all p.p.t. adversaries, all attackers output a solution with “small” probability

Hard problems (2)

- Diffie-Hellman problem

Given: $a, b \in_R 0, \dots, p - 2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p - 1$$

$$(g, g^a, g^b)$$

Find: g^{ab}

This problem is hard if for all p.p.t. adversaries, all attackers output a solution with “small” probability.

Notice this is just the
Diffie-Hellman scheme
re-written as a mathematical
assumption!

Hard problems (2)

- Diffie-Hellman problem

Given: $a, b \in_R 0, \dots, p - 2$

$$\langle g \rangle = \mathbb{G} \quad \text{order}(g) = p - 1$$

$$(g, g^a, g^b)$$

Find: g^{ab}

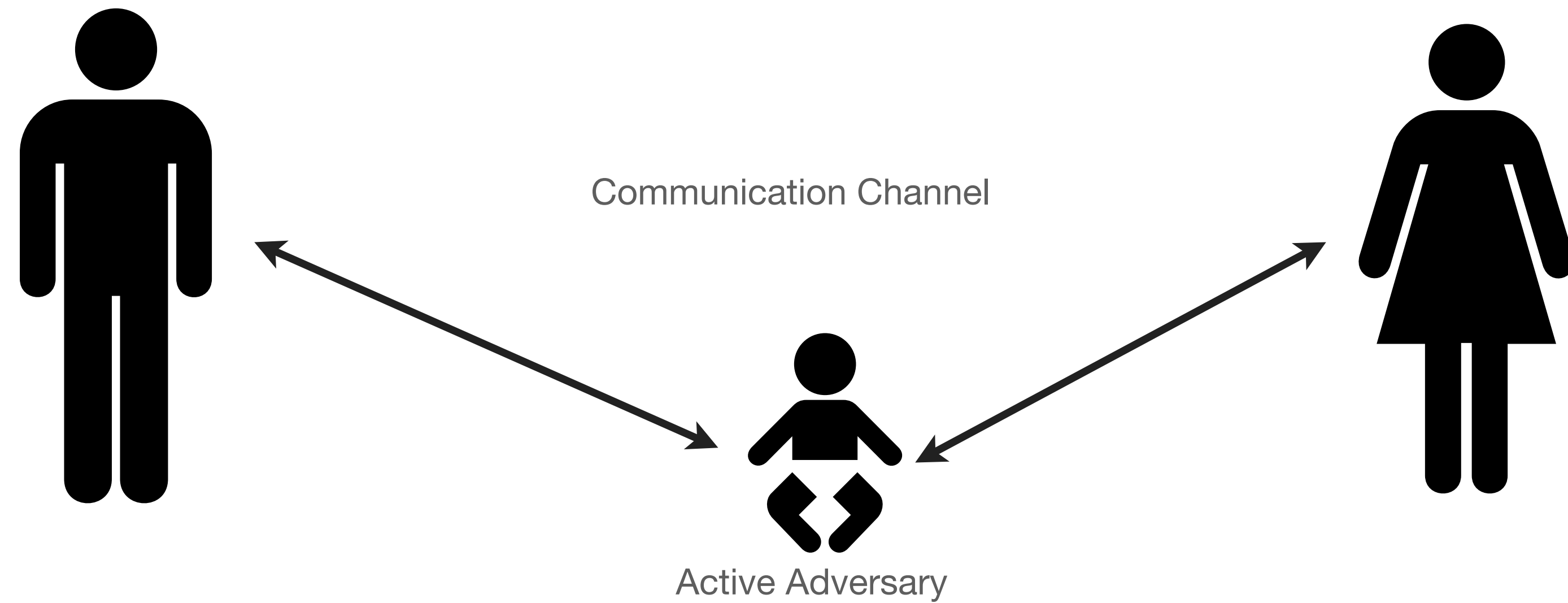
Notice this is just the
Diffie-Hellman scheme
re-written as a mathematical
assumption!

Note that for this to hold, the size
of p must be pretty large!

In practice, we typically assume
 p is at least 1024 bits. And 3072 bits
is the minimum in modern protocols!

This problem is hard if for all p.p.t. adversaries, all attackers output a solution with “small” probability.

What if we have an active adversary?

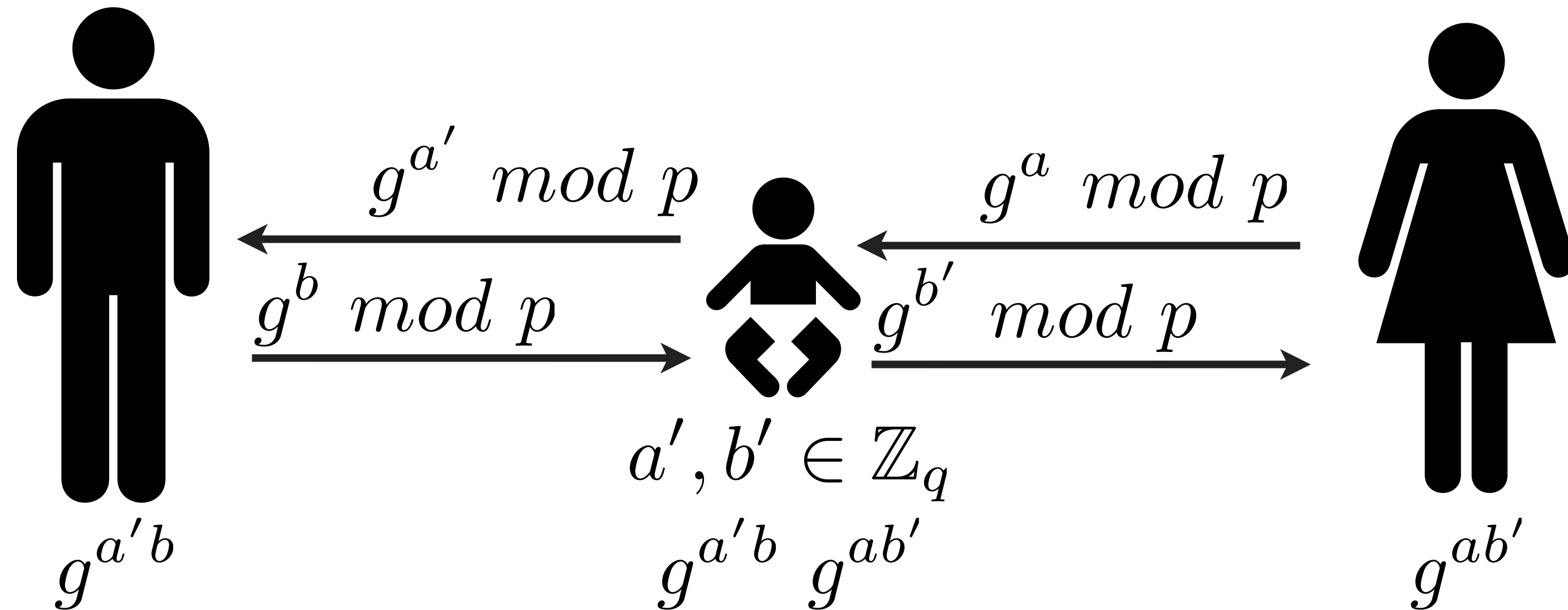


Man in the Middle

- Assume an active adversary:

$$b \in \mathbb{Z}_q$$

$$a \in \mathbb{Z}_q$$



Man in the Middle

- Caused by lack of authentication
- D-H lets us establish a shared key with anyone...
but that's the problem...
- We don't know if the person we're talking to is the right person
- Solution?

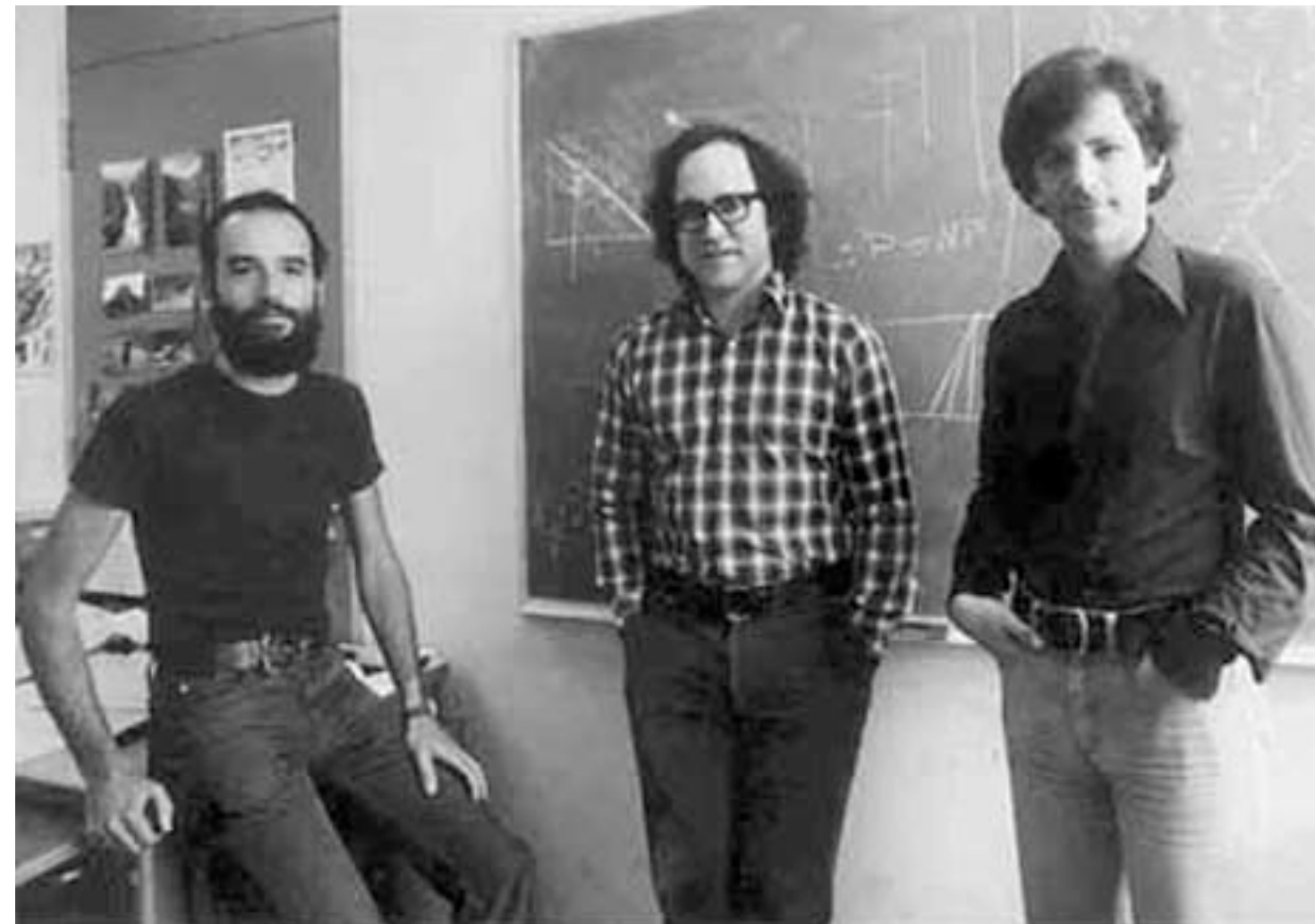
Preventing MITM

- Verify key via separate channel
- Password-based authentication
- Authentication via PKI



Public Key Encryption

- What if our recipient is offline?
- Key agreement protocols are interactive
- e.g., want to send an email



Public Key Encryption

